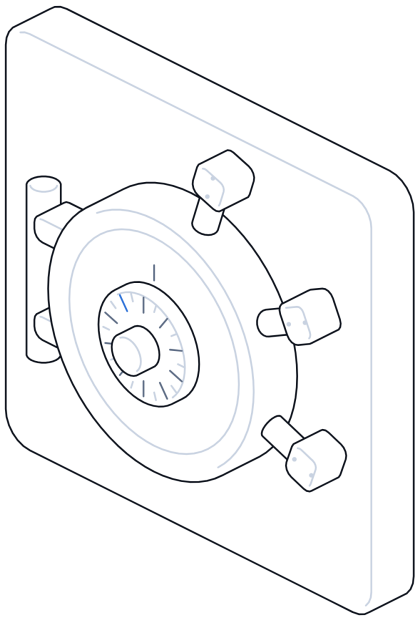


INTELLIGENCE REPORT · NORTH KOREA AND SOCIAL ENGINEERING

The job offer that empties the vault.

The record theft from Binance on 29 October 2026, the North Korean group the FBI blames for it, and the fake recruiters, poisoned coding tests and fake remote workers that make these attacks possible.

INSIDE

Contents

An evidence-based look at the October 2026 Binance theft, the North Korean groups blamed for it, the fake recruiters and fake IT workers behind their wider campaign, and what UK organisations should do now.

Executive summary 03

Key findings 04

At a glance 05

Timeline 06

01 Anatomy of the heist 07

02 How these groups operate 11

03 What it means for UK organisations 16

Sources 22

EXECUTIVE SUMMARY

The biggest theft in crypto history started, by the victim's own early account, with one engineer's laptop.

On 29 October 2026, attackers drained Binance hot wallets across several blockchains. Binance put the loss at about $6.3 billion, a figure it described as preliminary and unaudited, and said its initial investigation suggested a compromised DevOps engineer's laptop had given the attacker a way in.[1] Blockchain analysts put the total slightly higher, at about $6.4 billion.[2,3]

On 31 October the FBI attributed the theft to North Korea and named the group it calls TraderTraitor.[4] The same name appears in FBI attributions for the Bybit theft in 2025 and the DMM Bitcoin theft in 2024, and in a 2022 US advisory that described fake recruitment messages sent to DevOps and system administration staff at crypto firms.

How the Binance laptop was compromised has not been disclosed. Nobody official has said it was a fake job offer, and we do not claim it was. But the wider pattern is well documented: North Korean groups use fake recruiters, malicious coding tests and fake remote workers to get inside the organisations that hold money and code.

For UK businesses the risk is not limited to crypto. Any firm that hires remote developers or contractors can end up paying a North Korean IT worker, and the UK sanctions regime can treat that as a breach even when the employer did not know.

THE BOTTOM LINE

Treat hiring, contractor onboarding and developer laptops as part of your security perimeter. The most expensive breaches now begin with a conversation, not an exploit.

KEY FINDINGS

Seven things the evidence shows

01 **The loss figure is large but still moving.**

Binance's own estimate of about $6.3 billion is preliminary; Chainalysis and Elliptic put it at about $6.4 billion. Around $3 billion was frozen by issuers and partners.[1,2,3]

02 **Attribution is now official in the US, and disputed by Pyongyang.**

The FBI named TraderTraitor on 31 October.[4] North Korea called the claims "absurd rhetoric".[5]

03 **The way in looks human, not cryptographic.**

Binance reported no evidence that wallet private keys leaked. Its early account points to a compromised engineer's laptop and later to additional points of breach.[1,3]

04 **This is a repeat pattern.**

Bybit (2025) began with a compromised developer machine, and DMM Bitcoin (2024) began with a fake recruiter and a malicious pre-employment test.[6,7]

05 **Fake job interviews now operate at industrial scale.**

A September 2026 joint advisory says one North Korean group infected at least 30,000 devices in more than 100 countries through fake job interviews.[8]

06 **Fake IT workers are a revenue line and an access route.**

US Treasury says the IT worker schemes generated nearly $800 million in 2024, and officials link some of the workers to the same groups that run the fake interviews.[9,8]

07 **UK firms carry real legal exposure.**

OFSI says UK firms are almost certainly being targeted and that civil penalties can apply without proof the firm knew it was paying a North Korean worker.[10]

AT A GLANCE

The numbers behind the story

Figures for the Binance theft are early estimates and may change as investigations continue.

$6.3bn

Binance's preliminary, unaudited estimate of the 29 October theft. Chainalysis estimates about $6.4bn and Elliptic $6.43bn.[1,2,3]

628

Crypto addresses the FBI published as holding or having held proceeds: 608 Ethereum, 19 Bitcoin and one Solana.[3,4]

90%

Share of stolen assets Binance said it had replenished from company funds by 31 October.[11]

$1.5bn

The Bybit theft of February 2025, which the FBI also attributed to TraderTraitor. It was the previous record.[12]

30,000+

Devices infected through fake job interviews between December 2025 and July 2026, according to a seven-agency advisory.[8]

7 years

Maximum prison sentence for a criminal breach of UK financial sanctions, which can include paying a North Korean IT worker.[10]

TIMELINE

Six weeks that broke the record

From the Bitget theft to Pyongyang's denial. Times are UTC unless stated.

24 Sep 2026

Bitget loses hundreds of millions

Bitget reports an initial $351.6 million stolen, later revised to about $390 million, and says suspected North Korean actors were responsible.[13]

29 Oct, 20:05

Binance wallets start draining

TRM Labs dates the first unauthorised transfer to about 20:05 UTC. Funds leave hot wallets across multiple blockchains.[14]

29 to 30 Oct

Freezes and early attribution

Issuers and partners freeze about $3 billion. Chainalysis links the theft to TraderTraitor after funds mix with Bitget proceeds.[1,2]

30 Oct

Binance's preliminary account

Binance says the incident may involve a compromised DevOps engineer's laptop and that it found no evidence of a private key leak.[1]

31 Oct

FBI attributes the theft

The FBI names TraderTraitor, publishes 628 addresses and asks industry to block related transactions.[4,3]

31 Oct

Losses covered, attribution questioned

Binance says it has replenished 90% of stolen assets. Asked by reporters, the US President says it is not yet certain North Korea was behind it.[11,15]

1 Nov

Withdrawals reopen in phases

Binance begins a staged restart of withdrawals, starting with Bitcoin.[3]

2 Nov

North Korea denies involvement

State media rejects the US allegations as "absurd rhetoric".[5]

01

PART 01

Anatomy of the heist.

What happened at Binance, what is confirmed, and what is still a preliminary account.

01 What we know and do not know

02 How the drain worked

03 A pattern, not a one-off

WHAT HAPPENED

What we know, and what we do not

> **The attacker did not need to steal the keys. It made the exchange's own systems sign for it.**

The facts that are firm are few but significant. Funds began leaving Binance hot wallets on the evening of 29 October and moved across several chains within minutes.[14] TRM Labs said the theft took about 20 minutes.[16] Binance suspended withdrawals, kept deposits running and said users would not bear the loss.

The figures are not firm. Binance's estimate of about $6.3 billion is, in its own words, preliminary and unaudited.[1] Chainalysis reported about $6.4 billion, and Elliptic $6.43 billion across 11 blockchains, after excluding money it believes Binance moved itself.[2,3] Expect revisions as tokens are repriced and frozen funds are released or recovered.

The cause is less firm still. Binance's first update said the incident may involve a compromised DevOps engineer's laptop, which let an attacker reach a service container and submit withdrawal transactions.[1] Its co-chief executive later said the investigation had found additional points of breach and that the attack was not carried out by one person.[3] A full post-mortem has been promised.

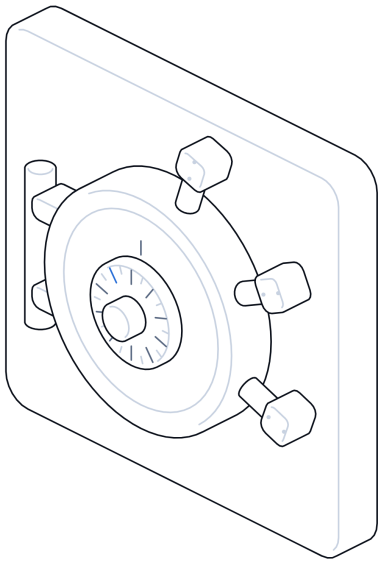
What matters for everyone else is the shape of the attack. Binance said it found no evidence that wallet private keys leaked.[1] Chainalysis described signed authorisations that let a hot wallet run code the attacker had deployed.[2] In plain terms, the attacker appears to have made Binance's own systems approve the transfers.

Attribution came quickly from analysts and then from the FBI. TRM Labs and Chainalysis linked the theft to TraderTraitor within hours; the FBI followed on 31 October.[16,2,4] North Korea denies it.[5] The US President also said, on the same day, that it was not yet certain.[15]

We report the FBI's attribution because it is the formal position of the investigating agency, and we label the rest as analyst assessment. What nobody has reported is how the engineer's laptop was compromised. That gap is exactly where the rest of this report sits.

HOW THE DRAIN WORKED

From one laptop to a sweep of hot wallets



01 **A foothold on a privileged device**

Binance's early account points to a compromised DevOps engineer's laptop that gave access to a service container.[1]

02 **Approval without stolen keys**

Signed authorisations let a hot wallet run attacker code; Binance said an EIP-7702 delegation bypassed normal approvals.[2,3]

03 **A race against the freeze**

The attacker swapped $325 million of freezable stablecoins into $285 million of ETH in about 20 minutes.[2]

04 **Automated laundering**

Thousands of fast transactions suggest automation. The FBI says proceeds are being converted mainly into ETH.[2,4]

THE PATTERN

A pattern, not a one-off

Four exchange thefts that US officials or analysts have tied to TraderTraitor. Entry points are as reported by the victim or investigators.

VICTIM AND DATE	REPORTED LOSS	REPORTED ENTRY POINT	ATTRIBUTION
DMM Bitcoin, May 2024	4,502.9 BTC, about $308m[7]	Fake LinkedIn recruiter sent a wallet firm employee a malicious coding test.	FBI, DC3 and Japan's NPA
Bybit, Feb 2025	About $1.5bn[12]	A Safe{Wallet} developer's Mac, likely via a social engineering lure.[6]	FBI
Bitget, Sep 2026	About $390m, revised[13]	Backend wallet system compromised and transaction data spoofed.	Suspected, per Bitget and analysts
Binance, Oct 2026	About $6.3bn, preliminary[1]	Compromised engineer's laptop, plus further breach points.	FBI; denied by North Korea

02

PART 02

The front door.

Why North Korean groups go after developers, and the two social engineering routes they use most.

01 Why crypto and developers

02 The poisoned coding test

03 The fake IT worker

MOTIVE AND METHOD

Why crypto, and why developers

> **Developers are the shortest path to the money, and a job offer is the shortest path to a developer.**

North Korea treats crypto theft as a revenue stream. Chainalysis estimated that North Korean actors stole at least $2.02 billion in 2025, a record before this year.[17] A monitoring group of 11 states, including the UK, found at least $1.65 billion stolen between January and September 2025 and linked the proceeds to weapons programmes.[18]

Crypto suits a sanctioned state. Assets move across borders in minutes, some cannot be frozen, and a single breach of an exchange can yield more than years of conventional fraud. The incentive is enormous and the pool of targets is global.

Developers are the shortest path to the money. The people who build and operate wallet infrastructure have access to signing systems, cloud consoles and deployment pipelines. As early as 2022, US agencies warned that TraderTraitor sent recruitment-themed messages to DevOps and system administration staff at crypto firms, offering high-paying jobs to get them to install trojanised apps.[19]

The 2024 DMM Bitcoin case shows the method end to end. Investigators said a fake LinkedIn recruiter sent an employee at a Japanese wallet software firm a malicious Python script dressed as a pre-employment test. Weeks later the attackers used stolen session cookies to manipulate a legitimate transaction.[7]

The FBI's 2024 warning to the industry was blunt: these campaigns are highly tailored and hard to detect, often start with research on professional networking sites, and frequently ask the target to run code or download an app.[20]

The lesson is that the attack surface is a person's curiosity and ambition, not a firewall. Good engineers like hard problems and better jobs. The attackers know it.

THE POISONED CODING TEST

How a fake interview becomes a breach



01 The approach

Per the September 2026 joint advisory, a recruiter for an AI, crypto or NFT company makes contact via social media, job boards or freelance platforms.[8]

02 The test

In a video interview the candidate downloads code to finish a task or fix a supposed video call error.

03 The payload

Malicious npm packages or VS Code settings install stealers and remote access trojans such as BeaverTail.

04 The pivot

Stolen credentials, wallet data and ID images are used against the victim, their employer and in fake job applications.

TWO ROUTES IN

The fake recruiter and the fake hire

The two schemes are different, but officials say some of the same people work on both.

ROUTE	FAKE RECRUITER	FAKE IT WORKER
Who is targeted	Your developers and engineers, often on personal accounts.	Your hiring managers, HR teams and contractor platforms.
The pretext	An attractive job, an urgent technical test.	A skilled remote contractor at a competitive rate.
What they want	Credentials, wallet data and a foothold on a work device.	Salary, then access to code, data and systems.
Typical tell	Pressure to run unfamiliar code or a special meeting tool.	Avoids video, inconsistent identity, odd payment requests.
Scale reported	30,000+ devices infected in eight months.[8]	Nearly $800m generated in 2024.[9]

THE FAKE IT WORKER

Hired, paid and inside the network

> **A fake candidate is not only an HR problem. It can be the first stage of an intrusion.**

The second route needs no malware at all. North Korea sends skilled IT workers abroad who pose as nationals of other countries and win remote jobs and freelance contracts. US Treasury said in March 2026 that these schemes generated nearly $800 million in 2024, with the regime taking most of the wages.[9]

Laptop farms make the deception work. A facilitator in the target country receives company laptops and lets the workers control them remotely, so the IP address looks local. In June 2025 the US Justice Department announced searches of 29 known or suspected laptop farms across 16 states and said the workers had obtained jobs at more than 100 US companies.[21]

Once inside, some workers do more than draw a salary. The FBI warned in January 2025 that workers who are discovered have held stolen code and data to ransom and in some cases published it.[22] The 2025 US cases also alleged theft of more than $900,000 in crypto and access to export-controlled defence data.[21]

The scheme is not only American. Google's threat intelligence team reported in April 2025 that the operation had expanded into Europe, found workers on UK projects, and found a laptop meant for New York operating in London.[23]

In July 2026, 11 governments including the UK issued a joint alert noting that the workers increasingly use AI to hide their identities.[24] The September 2026 advisory recorded face-swapping software in interviews and said WaterPlum actors and IT workers used the same IP addresses.[8]

The overlap matters. A fake candidate is not only a fraud risk for HR. It can be the first stage of the same kind of intrusion that hit Binance.

03

PART 03

The UK exposure.

Sanctions, legal risk and the practical steps that reduce both.

01 Sanctions and legal exposure

02 Where UK firms are exposed

03 Recommendations

SANCTIONS AND LIABILITY

You can breach sanctions without knowing it

> **Due diligence on remote hires is now a sanctions control, not just an HR process.**

HM Treasury's Office of Financial Sanctions Implementation (OFSI) published an advisory on North Korean IT workers in September 2024. It assessed that it is almost certain UK firms are being targeted by workers disguised as freelance third-country IT staff.[10]

The legal point is sharp. OFSI says people who employ or pay these workers could be directly or indirectly breaching financial sanctions. Civil monetary penalties can be imposed with no requirement for OFSI to show the person knew or suspected the conduct was a breach. A criminal breach can carry up to seven years in prison.[10]

OFSI names the sectors most exposed: IT, cryptocurrency, electronic money institutions, money service businesses and professional services.[10] That covers software houses, agencies, fintechs and any business that buys development work through platforms.

Reporting duties apply too. OFSI asks firms to report suspected targeting, and businesses in the regulated sector must still make suspicious activity reports to the National Crime Agency. OFSI asks them to quote the reference "OFSI - DPRK IT Workers Advisory - 0924".[10]

The UK has also been part of the wider response. It joined the 11-government alert on IT workers in July 2026, sits on the monitoring team that reported on North Korean cyber theft in 2025, and the NCSC co-sealed a 2024 advisory on another North Korean group targeting defence and engineering firms.[24,18,25]

This is not legal advice, and outcomes depend on facts. But the practical message is clear: due diligence on remote workers and contractors is now a sanctions control, not only an HR process. Document it.

WHERE YOU ARE EXPOSED

Four ways this reaches a UK business

You do not need to hold crypto to be a target.

Remote hiring

Developers, designers and support staff hired remotely or through freelance platforms can be fake personas run by North Korean workers.

Developer devices

A personal coding test run on a work laptop can hand an attacker credentials, session tokens and access to repositories.

Your supply chain

Agencies, outsourcers and subcontractors may unknowingly place a fake worker on your account.

Keys and payments

Anyone holding signing keys, treasury access or payment approval rights is a high-value target for both routes.

> **If someone you have never met in person can deploy code or approve payments, treat that role as high risk.**

RECOMMENDATIONS

Seven things to do now

Based on guidance from OFSI, the FBI and the September 2026 joint advisory.

01 Verify identity properly, and keep verifying

Live video, document checks and consistent details across profiles, re-checked after hire.[10,22]

02 Ban personal coding tests on work devices

Never on company laptops; use a separate, disposable environment.[20]

03 Lock down developer tooling

Open unknown VS Code projects in Restricted Mode, review package scripts and deploy endpoint detection.[8]

04 Separate who can approve money from who can deploy code

Multiple approvals from separate devices for any movement of funds or keys.

05 Control contractor access tightly

Least privilege, no commercial VPNs or unapproved remote desktop tools.

06 Flag payment and shipping anomalies

Crypto pay, third-party accounts or new shipping addresses are red flags.

07 Report and record

Report to OFSI, the NCSC or Action Fraud as appropriate, and keep records.

FOR THE BOARD

Questions to put to your leadership team

Ask for evidence, not reassurance.

HIRING AND SUPPLIERS

- ? How do we verify the identity of remote hires and contractors, and when did we last re-check them?
- ? Do our staffing agencies and outsourcers apply the same checks, and can they prove it?
- ? Would our controls catch a worker who never appears on camera?

ACCESS AND MONEY

- ? Who can approve a payment or a key operation from a single device?
- ? Can a developer run untrusted code on a laptop that can reach production?
- ? If we found a fake worker tomorrow, how fast could we cut access and assess sanctions exposure?

GLOSSARY

Terms used in this report

TraderTraitor

The FBI's name for a North Korean state-sponsored group focused on stealing crypto from exchanges and other firms.

WaterPlum / Contagious Interview

A North Korean group that uses fake job interviews and coding tests to infect developers' devices.

Hot wallet

A crypto wallet connected to the internet so it can process transactions quickly.

Laptop farm

A location where company laptops are kept online so remote workers can control them and appear local.

OFSI

HM Treasury's Office of Financial Sanctions Implementation, which enforces UK financial sanctions.

Stablecoin

A crypto token pegged to a currency. Issuers can often freeze them, which is why attackers swap them quickly.

EIP-7702

An Ethereum feature that lets an account delegate execution to code. Binance said its use bypassed normal approvals.

npm package

A reusable JavaScript code library. Malicious packages are a common way to deliver malware to developers.

Remote access trojan

Malware that gives an attacker remote control of an infected device.

Session token

Data that keeps a user logged in. Stealing it can let an attacker bypass multi-factor authentication.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

01 Yahoo Finance, Binance says a compromised engineer's laptop may have opened the $6.3B drain; no evidence of leaked keys (quoting Binance's security incident update), 30 Oct 2026, https://finance.yahoo.com/markets/crypto/articles/binance-says-compromised-engineer-laptop-161203953.html

02 Chainalysis, Binance hack: tracing the $6.4 billion theft to North Korea, 30 Oct 2026, https://www.chainalysis.com/blog/binance-exploit-latest-findings-and-response/

03 SecurityWeek, FBI flags over 600 addresses tied to North Korea's Binance heist, 2 Nov 2026, https://www.securityweek.com/fbi-flags-over-600-addresses-tied-to-north-koreas-binance-heist/

04 FBI, North Korea responsible for $6 billion+ Binance attack, 31 Oct 2026, https://www.fbi.gov/investigate/cyber/alerts/2026/north-korea-responsible-for-6-billion-binance-attack

05 U.S. News (Reuters), North Korea says claims linking it to Binance heist are 'absurd rhetoric', KCNA says, 2 Nov 2026, https://www.usnews.com/news/world/articles/2026-11-02/north-korea-says-claims-linking-it-to-binance-heist-are-absurd-rhetoric-kcna-says

06 The Hacker News, Safe{Wallet} confirms North Korean TraderTraitor hackers compromised developer machine in Bybit heist, 7 Mar 2025, https://thehackernews.com/2025/03/safewallet-confirms-north-korean.html

07 FBI, DC3 and NPA, Identification of North Korean cyber actors tracked as TraderTraitor responsible for theft of $308 million from Bitcoin.DMM.com, 23 Dec 2024, https://www.fbi.gov/news/press-releases/fbi-dc3-and-npa-identification-of-north-korean-cyber-actors-tracked-as-tradertraitor-responsible-for-theft-of-308-million-from-bitcoindmmcom

08 NPA, NCO, FBI, DC3, ASD's ACSC, BND and BfV, North Korean "WaterPlum" (Contagious Interview) cyber actor group targeting IT professionals; activities of North Korean IT workers, 18 Sep 2026, https://www.ic3.gov/CSA/2026/260918.pdf

09 US Treasury, Treasury sanctions facilitators of DPRK IT worker fraud targeting US businesses, 12 Mar 2026, https://home.treasury.gov/news/press-releases/sb0416

10 HM Treasury OFSI, North Korean IT workers advisory: signs to watch for, 12 Sep 2024, https://www.gov.uk/government/publications/north-korean-it-workers-advisory-signs-to-watch-for

11 NBC News (Reuters), FBI says North Korea was behind the $6.3 billion Binance crypto hack, 31 Oct 2026, https://www.nbcnews.com/business/business-news/fbi-says-north-korea-was-6-billion-binance-crypto-hack-rcna606758

12 FBI IC3, North Korea responsible for $1.5 billion Bybit hack (I-022625-PSA), 26 Feb 2025, https://www.ic3.gov/PSA/2025/PSA250226

SOURCES

Sources and notes

Sources continued. Source 04 is corroborated by sources 03 and 15.

13 The Hacker News, Bitget says suspected North Korean hackers behind theft, 25 Sep 2026, https://thehackernews.com/2026/09/bitget-says-suspected-north-korean.html

14 Cointelegraph, Recap: how Binance's record $6.3B hack unfolded, 30 Oct 2026, https://cointelegraph.com/news/recap-binances-record-63b-hack-unfolded

15 ABC News (AP), FBI blames North Korea for stolen billions from Binance in biggest hack in history, 31 Oct 2026, https://abcnews.com/Business/wireStory/fbi-blames-north-korea-stolen-billions-binance-biggest-137741287

16 TechCrunch, North Korean hackers blamed for stealing record $6.3B in Binance breach, 30 Oct 2026, https://techcrunch.com/2026/10/30/north-korean-hackers-blamed-for-stealing-record-6-3b-in-binance-breach/

17 Chainalysis, 2025 crypto theft: North Korea stole at least $2.02 billion, 18 Dec 2025, https://www.chainalysis.com/blog/crypto-hacking-stolen-funds-2026/

18 Gulf News (AFP), North Korea using crypto, IT workers to dodge UN sanctions: report (Multilateral Sanctions Monitoring Team), 25 Oct 2025, https://gulfnews.com/world/asia/north-korea-using-crypto-it-workers-to-dodge-un-sanctions-report-1.500319510

19 CISA, FBI and US Treasury, TraderTraitor: North Korean state-sponsored APT targets blockchain companies (AA22-108A), 18 Apr 2022, https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-108a

20 FBI IC3, North Korea aggressively targeting crypto industry with well-disguised social engineering attacks (I-090324-PSA), 3 Sep 2024, https://www.ic3.gov/PSA/2024/PSA240903

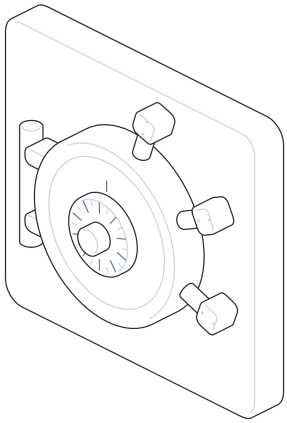
21 US Department of Justice, Coordinated, nationwide actions to combat North Korean remote IT workers' illicit revenue schemes, 30 Jun 2025, https://www.justice.gov/opa/pr/justice-department-announces-coordinated-nationwide-actions-combat-north-korean-remote

22 FBI IC3, North Korean IT workers conducting data extortion (I-012325-PSA), 23 Jan 2025, https://www.ic3.gov/PSA/2025/PSA250123

23 Google Threat Intelligence Group, DPRK IT workers expanding in scope and scale, 1 Apr 2025, https://cloud.google.com/blog/topics/threat-intelligence/dprk-it-workers-expanding-scope-scale

24 Baker McKenzie, Multiple governments issue joint alert on North Korean IT workers, 14 Aug 2026, https://sanctionsnews.bakermckenzie.com/multiple-governments-issue-joint-alert-on-north-korean-it-workers/

25 NCSC, NCSC and partners issue warning over North Korean state-sponsored cyber campaign to steal military and nuclear secrets, 25 Jul 2024, https://www.ncsc.gov.uk/news/ncsc-partners-vigilant-dprk-sponsored-cyber-campaign



TRANSPUTEC

Stop the heist before the hire.

We help UK organisations tighten remote hiring, contractor access and developer device security, so a job offer or a new hire never becomes the way in.

Book a security review

transputec.com

PUT IT INTO PRACTICE

Companion playbook: Hire without the heist